

Fase 3: Tratamiento del Riesgo y Plan de Acción - OmniSalud

Implementación de Controles Normativos y Gobernanza (ISO 31000 | ISO 27701)

Unidad de Negocio: OmniSalud (Servicios Clínicos y Telemedicina)

Responsable de Cumplimiento: Gonzalo Vega Batyi, Abogado / DPO

Referencia de Riesgo: Mitigación de impacto extremo por vulneración de datos sensibles (404 casos).

Estatus: Fase de Ejecución de Controles.

1. Selección de la Estrategia de Tratamiento (ISO 31000: 6.5.2)

Habiendo evaluado un nivel de riesgo **Extremo** en la Fase 2 debido a la contaminación cruzada de datos de salud y financieros, la dirección estratégica determina la aplicación de una **Estrategia de Mitigación y Aislamiento**.

El objetivo es reducir la probabilidad de ocurrencia de un incidente de privacidad y minimizar el impacto legal ante una fiscalización de la Agencia de Protección de Datos Personales (APDP).

2. Controles Organizativos: Manuales y Protocolos

Estrategias en cumplimiento, establecer la capa de gobernanza administrativa que rige el comportamiento de la organización y delimita responsabilidades.

2.1 Manual de Procedimientos para el Administrador de Unidad

Este manual constituye la norma interna de obligado cumplimiento para el Administrador de OmniSalud:

- Segregación Lógica de Datos (Data Siloing):** Se prohíbe el acceso de cualquier personal externo a la unidad a la columna **Patologia_Cronica**. La base de datos debe ser aislada mediante credenciales de acceso exclusivas para personal clínico.
- Protocolo de Gestión de Identidades:** Se instruye la eliminación del uso del **ID_Interno** compartido para reportes de gestión. En su lugar, se implementará un sistema de **Tokenización** de un solo uso.
- Auditoría de Acceso Recurrente:** El Administrador deberá realizar una revisión quincenal de los **logs** de acceso para detectar consultas anómalas desde las filiales de Retail o Banca.

2.2 Protocolo de Reserva Legal y Secreto Profesional (Personal Operativo)

Se implementa un anexo contractual para los 4 empleados de la unidad, reforzando las obligaciones derivadas de la Ley 21.719:

- Deber de Confidencialidad Reforzada:** El personal declara conocer las sanciones civiles y penales asociadas a la filtración de datos sensibles.
- Prohibición de Procesamiento Paralelo:** Queda estrictamente prohibido el uso de herramientas de IA no autorizadas o nubes personales para procesar información de pacientes.

3. Directriz de Seguridad Técnica (Vínculo Ley 21.663)

Desde la perspectiva de la Ley Marco de Ciberseguridad, se definen los requisitos mínimos que el área de TI del Holding debe implementar para la infraestructura de OmniSalud:

- **Cifrado en Reposo y Tránsito:** Implementación de cifrado AES-256 para la tabla de pacientes.
- **Seudonimización Irreversible:** Para los fines de perfilamiento comercial del Holding, OmniSalud solo entregará datos agregados y disociados, eliminando cualquier posibilidad de re-identificación de los 404 ciudadanos afectados.

4. Matriz de Riesgo Residual

Tras la aplicación de los manuales y controles descritos, el perfil de riesgo de OmniSalud se actualiza para reflejar la eficacia de la intervención:

Riesgo Identificado	Nivel Inherente	Control Implementado	Riesgo Residual
Perfilamiento Ilícito	Extremo	Manual de Aislamiento de Finalidad	Bajo
Vulneración de Secreto	Alto	Protocolo de Secreto Profesional	Bajo
Falta de Base Legal	Crítico	Regularización de Consentimientos	Medio
Sanción APDP (20k UTM)	Extremo	Acreditación de Responsabilidad Proactiva	Bajo

5. Conclusión de la Auditoría - Unidad OmniSalud

Con la entrega de este Plan de Acción y la puesta en marcha de los Manuales de Procedimiento, se considera que la unidad **OmniSalud** ha alcanzado un nivel de cumplimiento adecuado para operar bajo los estándares de la Ley 21.719.

Certificación del DPO: La unidad ha demostrado la implementación de "Privacidad desde el Diseño" y cuenta con la documentación necesaria para acreditar debida diligencia ante una auditoría externa o inspección gubernamental.